SundAI / Praktisk checklista

De 5 viktigaste säkerhetsriskerna med AI-agenter

Granskad: 14 oktober 2026

01 / Behörigheter och identiteter

☐ Risk 1: För breda verktygsbehörigheter. Ge verktyg avgränsade identiteter och godkänn känsliga åtgärder. Testa att läsuppgifter inte kan skriva.

☐ Risk 2: Svaga eller delade identiteter. Blockera svaga lösenord, använd lämplig MFA och byt exponerade hemligheter. Testa återkallelse med ett syntetiskt konto.

Spara underlaget

Punkt / ägare	Underlag / nästa åtgärd

02 / Opålitlig indata och sökning

☐ Risk 3: Prompt injection och dataexfiltrering. Behandla dokument, webbsidor och mejl som opålitliga. Separera instruktioner från data; begränsa verktygsmottagare. Testa ofarligt motstridigt innehåll i säker miljö.

☐ Risk 4: Sökning läcker över roller eller kunder. Kontrollera behörighet före sökning och verktygskörning. Testa samma fråga med en tillåten och en otillåten användare.

Spara underlaget

Punkt / ägare	Underlag / nästa åtgärd

03 / Åtgärder och återställning

☐ Risk 5: Obegränsade åtgärder eller kostnader. Sätt gränser, övervaka, kräv godkännande och definiera stopp. Testa en gränsöverskridning med syntetiska data.

☐ Spara tillåten åtgärd, nekad åtgärd, resultat, ägare, datum och nästa steg. Ett bra svar bevisar inte en säker agent.

☐ Börja med ett arbetsflöde. Utöka åtkomst först när kontroller har demonstrerats.

Spara underlaget

Punkt / ägare	Underlag / nästa åtgärd

Ditt nästa steg

Ta ett konkret beslut till AI Decision Review för €490. Omfattning, tid och tillämplig moms avtalas före accept. Ett formulär bekräftar inget köp eller möte.

sundaibot.com/sv/ai-decision-review/

Vägledning, inte certifiering eller juridisk rådgivning. Kontrollera tillämplighet och gällande lag för systemet.

Granskad: 14 oktober 2026

OWASP · authentication guidance

https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

NIST SP 800-63B-4 · passwords

https://pages.nist.gov/800-63-4/sp800-63b/passwords/

Datatilsynet · security risk assessment

https://www.datatilsynet.dk/regler-og-vejledning/behandlingssikkerhed/risikovurdering

GDPR · official EUR-Lex

https://eur-lex.europa.eu/eli/reg/2016/679/oj

Contact: eririmo@protonmail.com · UK company 13813344